

Arquitectura resumida

- **Backend:** Django 5 + API tipo FastAPI (django-ninja), corriendo en Render, con base de datos PostgreSQL administrada por Render (región Oregon, EE.UU.).
- **Frontend:** Next.js 14, también en Render, servido bajo dominio propio **inspiratoria.aplify.com**.
- **Autenticación:** tokens de sesión opacos, almacenados como hash (SHA-256) en base de datos — nunca se guarda el token en texto plano. Expiran a las 8 horas, o 30 días si el usuario marca “recordarme”.
- **Autorización:** cada usuario queda ligado a su empresa (*company_id*). Todo endpoint valida que un usuario solo pueda ver o editar datos de su propia empresa, salvo roles administradores de Inspiratoria.

Seguridad implementada

- **HTTPS forzado** — todo el tráfico se redirige a HTTPS, con HSTS activado (el navegador ya no intenta HTTP tras la primera visita) y cookies marcadas como *Secure*.
- **Tokens de sesión reales** — recientemente reforzados: opacos, hasheados, con expiración y revocación del lado del servidor.
- **2FA obligatorio (TOTP)** — cada usuario activa su cuenta con un código enviado por correo y luego debe enrolar un autenticador (Google Authenticator / Microsoft Authenticator) antes de poder ingresar. El login exige el código TOTP siempre; no es opcional.
- **CORS restringido** — el backend solo acepta solicitudes desde los dominios oficiales de Inspiratoria, no desde cualquier sitio externo.
- **Contraseñas** — hash estándar de la industria (PBKDF2) más validaciones de largo mínimo y contra contraseñas comunes.
- **Aislamiento por empresa** — verificado exhaustivamente: un usuario de SQM solo puede ver los datos de SQM, nunca los de otra empresa cliente de la plataforma.
- **Restricciones en subida de archivos** (logos, avatares) — validación de tipo y tamaño máximo permitido.

¿Se bloqueará la IP de los computadores de SQM? — No.

La plataforma no implementa bloqueo ni límite de accesos por dirección IP. Si muchas personas de SQM ingresan desde la misma IP de oficina (típico con NAT corporativo), de nuestro lado nunca se bloquea a nadie por eso. El único riesgo real está del lado de SQM: que su propio firewall o proxy corporativo bloquee la salida hacia nuestro dominio antes de que la solicitud nos llegue.

Qué pedirle al equipo de TI de SQM

- 1 **Whitelistear el dominio** `inspiratoria.aplifty.com` en su proxy/firewall corporativo (Zscaler, Fortinet, Palo Alto, etc.) — pedirlo por dominio, no por IP, ya que Render no usa direcciones IP fijas y pueden cambiar sin aviso.
- 2 **Permitir salida HTTPS (puerto 443)** hacia ese dominio desde la red donde estarán sus colaboradores (oficina, y VPN corporativa si usan split-tunnel).
- 3 **Whitelistear el remitente de los correos de activación y OTP** en su filtro antispam (Microsoft Defender, Proofpoint, etc.) — si no, los códigos de activación pueden caer en spam o cuarentena y los usuarios quedan bloqueados en el primer paso, no por la plataforma sino por su propio antispam.
- 4 **Confirmar que cada colaborador tenga instalado un autenticador** (Google Authenticator o Microsoft Authenticator) en su celular o computador — el 2FA es obligatorio desde el primer ingreso.
- 5 **Tener lista la respuesta sobre residencia de datos** si su equipo de compliance lo pregunta: los datos se alojan en servidores de Render en EE.UU. (Oregon).

Documento de uso interno para preparación de reunión. No incluye detalles técnicos sensibles de implementación.